



Nov 19, 2024 · 3 min read

How to perform reconnaissance on a web application? Explain the methodology of tools you use to perform reconnaissance?

Reconnaissance is one of the most important steps in web application penetration testing as this step gives us a good idea about the technology stack being used, subdomains, endpoints, etc. We will discuss various methodologies and tools we can use to perform reconnaissance on web application:

1. Understanding Technology stack: It is very important to understand the technology stack of the web application as it helps in determining the test cases for exploitation. Getting to know the server, database, libraries being used, Web application firewall, etc helps us craft test cases specifically for that particular technology:

The following are the tools which we can use to understand technology stack:

a. Wappalyzer - This is a web extension which analyzes the web application and lists down the technology stack of the website along with versions if they are available. As soon as you load up the website, Wappalyzer extension starts pulling up the technology stacks.

Link: <https://www.wappalyzer.com/>

b. Build with - This is a web tool in which if we enter the URL of the website whose technology stack we want to know, it will list down the technology stack along with the version if they're available.

Link: <https://builtwith.com/>

c. OWASP Penetration Testing Kit - This is an extension of the browser which populates as soon as you open up the website just like wappalyzer. This extension has various other features which let us know the CVE's of vulnerable libraries, if secure headers are being used or not, any web application firewalls are being used, etc. This tool can be considered like a swiss knife as there are lots of things this tool can do apart from telling about the technology stack of the web application.

Link: <https://owasp.org/www-project-penetration-testing-kit/>

2. Directory fuzzing - There are endpoints or configuration files which might be accessible publicly but are not found easily. To access these endpoints, we use directory fuzzing tools to find those endpoints. There are wordlists which can be used to perform directory fuzzing. Please also note that these tools can also be used for subdomain enumeration.

The following are the tools which we can use to perform directory fuzzing:

a. FFUF - Fuzz Faster U Fool is a tool which can be used to perform directory fuzzing and it also has many other applications. This tool uses the concept of variable to fuzz through the directory or request of the web application.

"ffuf -u http://localhost:3000/FUZZ -w /usr/share/wordlists/SecLists/Discovery/Web-Content/big.txt" -> The example given, we wanted to fuzz the web application endpoint so we have provided the variable 'FUZZ'. The flag '-w' is used to provide the wordlist and '-u' is used to provide the URL.

Link: <https://github.com/ffuf/ffuf>

b. dirbuster - This is a GUI based tool made by OWASP. In this tool, we have to provide the URL, we can set the recursiveness of the path and we can even select threads i.e

concurrent requests at a time.
Link: <https://www.kali.org/tools/dirbuster/>

c. subfinder - This is another command line tool specifically created to enumerate subdomains.
"subfinder -d tesla.com -v" -> In this example, we provide the domain with -d flag and we use -v flag to give us very detailed output.
Link: <https://github.com/projectdiscovery/subfinder>
Please note that there are many other tools for directory fuzzing and subdomain enumeration, but follow these same principles.

3. Automated Recon Tools - These tools really come in handy since they automate recon processes in a way. These tools will scan through the web application and inform us about any security vulnerabilities which they come across while scanning.
The following are the automated tools which we can use to perform reconnaissance:

a. AMASS - This command line tool is developed by OWASP. It covers a lot of functionality and has the feature of scaling up the scanning process by integrating other tools via API keys. Following is the link of user guide: https://github.com/owasp-amass/amass/blob/master/doc/user_guide.md
Link: <https://github.com/owasp-amass/amass>

b. Nuclei - This is a vulnerability scanner which not only scans web applications, but also cloud environments and networks. By default, nuclei uses templates to perform vulnerability scanning. These templates can be used to target or scan a specific technology but if not mentioned, use default templates. These templates are also developed by communities which are open source, hence making this tool very efficient.
To scan a web application, we simply have to use: nuclei -u tesla.com
Link: <https://github.com/projectdiscovery/nuclei>
Please note that there are changes of false positives getting reported by these automated tools. Make sure to validate the findings provided by the automated tools.

4. Wayback machine - This is one of the most important tools for recon. Basically, we can see the web application from the day it was started. Many web applications stored sensitive information in the front end and this information can be easily retrieved using the wayback machine tool.
Link: <https://web.archive.org/>

[Web Application Security](#) · [Interview Questions](#)

in 

Recent Posts

[See All](#)

How to intercept traffic from Android apps? Explain with...

When performing the android pentesting, the penetration tester needs to install the burp suite certificate directly as a system...

What is your methodology and approach when testing...

Before moving forward with the approach to test a wordpress website, let's discuss what is a wordpress. So, WordPress is a...

What is the use of the Sequencer tab in Burpsuite?

Burp Sequencer is a sophisticated tool which is used to analyze the quality of randomness of data or tokens,...